



Final Guidelines on the management of ESG: risks released by the EBA

15 January 2026

Environmental, Social and Governance (ESG) refers to the identification, management and reporting of non-financial risks across these three areas. ESG is now firmly in the regulatory spotlight as supervisors increase expectations and firms face growing climate, societal, and stakeholder pressures. As a result, financial institutions are expected to demonstrate how ESG risks are understood, governed and integrated into strategy, operations and everyday decision-making in a proportionate and meaningful way.

Current regulations and expectations:

The European Banking Authority (EBA) expect ESG to be integrated across governance, risk management, and reporting, with clear board oversight. The guidelines will apply from 11 January 2026, except for small and non-complex institutions, for which the guidelines will apply at the latest from 11 January 2027.

EU:

- The EBA has published [final Guidelines on the management of ESG risks](#), requiring institutions to identify, measure, manage and monitor ESG risks as part of prudential and risk management frameworks from January 2026.
- [The Corporate Sustainability Reporting Directive \(CSRD\)](#) and [Sustainable Finance Disclosure Regulation \(SFDR\)](#) introduce reporting and disclosure obligations to enhance transparency for investors and stakeholders.

The ESG framework is built around three pillars, which represent areas where a firm can have a positive or negative impact, either directly or indirectly.

- **Environmental:** climate change, energy use and other environmental risks.
- **Social:** impacts on customers, employees and communities, including conduct and inclusion risks.
- **Governance:** Board oversight, internal controls and decision-making processes to ensure effective risk management.

ESG affects all businesses, influencing operations, reputation, and financial performance. Regulatory expectations are most advanced for financial services firms, though SMEs may still face ESG pressures from investors, clients, or supply chain partners.

Originally a voluntary, investor-led concept, ESG has evolved into a core element of corporate governance and risk management. Global standards and reporting frameworks have transformed ESG from a reputational concern into a structured, measurable part of business strategy.

When an EMI would not be treated as SNCI-equivalent

An EMI will lose the “small and non-complex” treatment in practice if it has:

- Very large transaction volumes
- Significant safeguarding complexity
- Multiple outsourcing layers (especially cloud + payments)
- High-risk geographies
- Crypto-adjacent activity
- Group complexity
- Aggressive growth or M&A
- Prior supervisory findings

Impact on financial institutions

The regulatory landscape has practical implications for financial institutions:

- KYC and EDD questionnaires should be updated to reflect revised disclosure expectations.
- Banks are still required to manage ESG and climate risks. However, they will increasingly rely on estimated or proxy data from smaller clients, shifting responsibility for ESG assessment onto the institution itself.

Common gaps and challenges

Firms frequently encounter difficulties in implementing ESG effectively, facing a range of operational, regulatory, and reporting challenges.

- **Complex regulatory frameworks:** overlapping and frequently updated standards can create uncertainty for firms, as they may be unclear on which requirements to follow, how to align reporting across frameworks, and how to interpret evolving guidance.
- **Data quality and availability:** many firms lack reliable, complete, or timely ESG data, which makes it challenging to measure risks accurately, set meaningful targets, and track progress over time.
- **Cost and resourcing constraints:** smaller firms often lack the financial and human resources to implement new ESG processes, including data collection, reporting systems, and staff training. Limited budgets and competing operational priorities can slow ESG adoption and make it difficult to maintain compliance with evolving regulatory requirements.
- **Greenwashing risks:** institutions offering investment or insurance products face strict disclosure rules and increasing enforcement regarding misleading sustainability claims.

Building an effective and proportionate ESG framework

Firms should prioritise several key areas in order to develop an ESG framework that is both effective and proportionate to their size, complexity, and risk profile.

- **Strengthen ESG oversight:** assign clear ownership of ESG risks (e.g., CRO, COO, Head of Risk and Compliance). If budget allows, consider an ESG committee to coordinate oversight across the

business.

- **Build a basic ESG data plan:** use proxy data where direct measurements are unavailable. For example, if a small client does not report emissions, industry averages can be applied.
- **Tighten product and marketing controls:** especially relevant for investment firms, review all ESG claims made publicly to ensure accuracy.
- **Prepare for regulatory reviews:** document ESG risk processes clearly, so the firm can respond efficiently to changing regulatory expectations.
- **Training:** provide basic ESG training for compliance, risk, and product teams to reduce mislabelling of products or failure to meet expectations.

We recommend a framework in which proportionality is embedded across all key ESG elements, ensuring that governance, processes, and controls are tailored to the firm's risk exposure.

- **Governance and accountability:** for firms with limited activities or low ESG risk, governance can remain lightweight, such as a single senior manager overseeing ESG. The ESG policy should reflect the business model, for example, a payments firm may focus on client assessments, ethical marketing, and data protection.
- **ESG data structure:** accept that client ESG data gaps are common. Maintain a basic spreadsheet of key data points when necessary.
- **Greenwashing controls:** align the level of control with the strength of ESG claims made publicly. If ESG claims are limited, minimal controls are required.
- **Third-party oversight:** for partners, vendors, or distributors, include ESG checks during onboarding. Simple checks, such as legal compliance, ethical conduct, and the absence of controversies, are sufficient for most firms.
- **Training:** provide targeted, concise ESG training modules for relevant teams, proportionate to their responsibilities.

How ESG is measured and assessed

ESG performance is assessed through external ratings and publicly available disclosures, providing investors and stakeholders insight into sustainability practices and governance. Firms should also conduct internal ESG self-assessments to identify gaps, manage risks, and embed ESG into governance, risk management, and reporting frameworks.

Together, these external and internal measures help firms build a clearer picture of their ESG performance and ensure their approach is aligned with regulatory expectations.

How fscom can support

fscom supports financial services firms to implement and operationalise ESG frameworks through tailored approaches that embed ESG into governance, risk management, and reporting.

- **Framework design:** develop proportionate and effective ESG strategies embedded in business processes.
- **Health checks:** assess current ESG governance, risk management, and reporting practices.

Our approach ensures ESG is not just compliant, but fully operational and integrated into decision-making, risk oversight, and reporting, giving firms confidence in meeting regulatory expectations.

This post contains a general summary of advice and is not a complete or definitive statement of the law. Specific advice should be obtained where appropriate.